Web Server Incident

Group 1:
Michael
Cat
Gokul
Aparna

Task: A company’s web server has been breached through their website, our team arrived just in time to take a forensic image of the running system and it’s memory for further analysis.

Questions:

- What type of attacks has been performed on the box?
- How many users has the attacker(s) added to the box, and how were they added?
- What leftovers (files, tools, info, etc) did the attacker(s) leave behind? (assume our team arrived in time and the attacker(s) couldn't clean and cover their tracks)
- What software has been installed on the box, and were they installed by the attacker(s) or not?
- Using memory forensics, can you identify the type of shellcode used?
- What is the timeline analysis for all events that happened on the box?
- What is your hypothesis for the case, and what is your approach in solving it?
- Is there anything else you would like to add?

Tools Used:

- Autopsy
- Volatility
- FTK Imager

1. What type of attacks have been performed on the box?

- Brute Force Attack
- SQL Injection
- Command Injection
- Local File Inclusion
- Cross-site Scripting
- Unrestricted file uploads
- Web-shells

Brute Force Attack

```
192.168.56.102 - - [02/Sep/2015:01:43:30 -0700] "GET /dvwa/vulnerabilities/brute/.?username=admin&Login=Login&password=password HTTP/1.1" 200 4778 "http://192.168.56.101/dvwa/vulnerabilities/brute/." "Mo
192.168.56.102 - - [02/Sep/2015:01:43:30 -0700] "GET /dvwa/vulnerabilities/brute/?username=admin&Login=Login&password=password HTTP/1.1" 200 4778 "http://192.168.56.101/dvwa/vulnerabilities/brute/" "Moz
192.168.56.102 - - [02/Sep/2015:01:44:35 -0700] "GET /dvwa/vulnerabilities/brute/.?username=admin&Login=Login&password=password&username=admin&Login=Login&password=password HTTP/1.1" 200 4870 "
192.168.56.102 - - [02/Sep/2015:01:44:35 -0700] "GET /dvwa/vulnerabilities/brute/?username=admin&Login=Login&password=password&username=admin&Login=Login&password=password HTTP/1.1" 200 4784 "
```

SQL Injection

```
PS E:\xampp\apache\logs> Get-Content "E:\xampp\apache\logs\access.log" |
>>     Where-Object { $_ -match "192\.168\.56\.102" } |
>>     Out-File "D:\DFIR\DFIR_Web Server Case\analysis\192-168-56-102-access_log.log"
PS E:\xampp\apache\logs> gc "D:\DFIR\DFIR_Web Server Case\analysis\192-168-56-102-access_log.log" |
>>   % { if ($_ -match '"[^"]*"[^"]*"([^"]*)"$') { $matches[1] } } |
>>   group |
>>   sort count -desc |
>>   ft count, name -auto

Count Name
----- ----
 3621 sqlmap/1.0-dev-nongit-20150902 (http://sqlmap.org)
  510 Mozilla/5.0 (compatible; MSIE 9.0; Windows NT 6.1; Win64; x64; Trident/5.0)
  215 Mozilla/5.0 (X11; Linux x86_64; rv:38.0) Gecko/20100101 Firefox/38.0 Iceweasel/38.2.0
   28 Mozilla/5.0 (X11; Linux i686; rv:31.0) Gecko/20100101 Firefox/31.0 Iceweasel/31.4.0
   22 Mozilla/4.0 (compatible; MSIE 6.0;)
    6 Mozilla/4.0 (compatible; MSIE 7.0; Windows NT 6.0; SLCC1; .NET CLR 2.0.50727; .NET CLR 3.0.04506)
    2 Python-urllib/2.7
```

```
192.168.56.102 - - [02/Sep/2015:04:23:12 -0700] "GET /dvwa/vulnerabilities/sqli/?id=2&Submit=Submit HTTP/1.1" 2
192.168.56.102 - - [02/Sep/2015:04:23:12 -0700] "GET /dvwa/vulnerabilities/sqli/?id=2&Submit=Submit&vJtN%3D1
192.168.56.102 - - [02/Sep/2015:04:23:12 -0700] "GET /dvwa/vulnerabilities/sqli/?id=2%27%20UNION%20ALL%20
192.168.56.102 - - [02/Sep/2015:04:23:44 -0700] "GET /dvwa/vulnerabilities/sqli/?id=2&Submit=Submit HTTP/1.1" 2
192.168.56.102 - - [02/Sep/2015:04:23:44 -0700] "GET /dvwa/vulnerabilities/sqli/?id=2&Submit=Submit&lLGo%3D5
192.168.56.102 - - [02/Sep/2015:04:23:44 -0700] "GET /dvwa/vulnerabilities/sqli/?id=2%27%20UNION%20ALL%20
192.168.56.102 - - [02/Sep/2015:04:23:45 -0700] "GET /dvwa/vulnerabilities/sqli/?id=2%27%20UNION%20ALL%20
192.168.56.102 - - [02/Sep/2015:04:23:45 -0700] "GET /dvwa/vulnerabilities/sqli/?id=2%27%20UNION%20ALL%20
192.168.56.102 - - [02/Sep/2015:04:23:45 -0700] "GET /dvwa/vulnerabilities/sqli/?id=2%27%20UNION%20ALL%20
192.168.56.102 - - [02/Sep/2015:04:23:45 -0700] "GET /dvwa/vulnerabilities/sqli/?id=2%27%20UNION%20ALL%20
192.168.56.102 - - [02/Sep/2015:04:23:45 -0700] "GET /dvwa/vulnerabilities/sqli/?id=2%27%20UNION%20ALL%20
```

Command Injection

```
192.168.56.102 - - [02/Sep/2015:01:43:29 -0700] "GET /dvwa/vulnerabilities/exec/ HTTP/1.1" 200 4471 "-" "Mozilla/5.0 (compatible; MSIE 9.0; Windows NT 6.1; Win64; x64; Trident/5.0)"
192.168.56.102 - - [02/Sep/2015:01:43:29 -0700] "GET /dvwa/vulnerabilities/exec/. HTTP/1.1" 200 4471 "http://192.168.56.101/dvwa/index.php" "Mozilla/5.0 (compatible; MSIE 9.0; Windows NT 6.1; Win64; x64; Trident/5.0)"
192.168.56.102 - - [02/Sep/2015:01:43:30 -0700] "GET /dvwa/vulnerabilities/exec/ HTTP/1.1" 200 4471 "http://192.168.56.101/dvwa/vulnerabilities/" "Mozilla/5.0 (compatible; MSIE 9.0; Windows NT 6.1; Win64; x64; Trident/5.0)"
192.168.56.102 - - [02/Sep/2015:01:50:03 -0700] "GET /dvwa/vulnerabilities/exec/ HTTP/1.1" 200 4468 "http://192.168.56.101/dvwa/security.php" "Mozilla/5.0 (X11; Linux x86_64; rv:38.0) Gecko/20100101 Firefox/38.0 Iceweasel/38.2.0"
192.168.56.102 - - [02/Sep/2015:01:50:03 -0700] "GET /dvwa/vulnerabilities/exec/ HTTP/1.1" 200 4468 "http://192.168.56.101/dvwa/security.php" "Mozilla/5.0 (X11; Linux x86_64; rv:38.0) Gecko/20100101 Firefox/38.0 Iceweasel/38.2.0"
192.168.56.102 - - [02/Sep/2015:01:50:33 -0700] "POST /dvwa/vulnerabilities/exec/ HTTP/1.1" 200 4835 "http://192.168.56.101/dvwa/vulnerabilities/exec/" "Mozilla/5.0 (X11; Linux x86_64; rv:38.0) Gecko/20100101 Firefox/38.0 Iceweasel/38.2.0"
192.168.56.102 - - [02/Sep/2015:01:50:51 -0700] "POST /dvwa/vulnerabilities/exec/ HTTP/1.1" 200 4934 "http://192.168.56.101/dvwa/vulnerabilities/exec/" "Mozilla/5.0 (X11; Linux x86_64; rv:38.0) Gecko/20100101 Firefox/38.0 Iceweasel/38.2.0"
192.168.56.102 - - [02/Sep/2015:01:51:14 -0700] "POST /dvwa/vulnerabilities/exec/ HTTP/1.1" 200 5379 "http://192.168.56.101/dvwa/vulnerabilities/exec/" "Mozilla/5.0 (X11; Linux x86_64; rv:38.0) Gecko/20100101 Firefox/38.0 Iceweasel/38.2.0"
192.168.56.102 - - [02/Sep/2015:01:52:06 -0700] "GET /dvwa/security.php HTTP/1.1" 200 4229 "http://192.168.56.101/dvwa/vulnerabilities/exec/" "Mozilla/5.0 (X11; Linux x86_64; rv:38.0) Gecko/20100101 Firefox/38.0 Iceweasel/38.2.0"
192.168.56.102 - - [02/Sep/2015:01:52:06 -0700] "GET /dvwa/security.php HTTP/1.1" 200 4229 "http://192.168.56.101/dvwa/vulnerabilities/exec/" "Mozilla/5.0 (X11; Linux x86_64; rv:38.0) Gecko/20100101 Firefox/38.0 Iceweasel/38.2.0"
192.168.56.102 - - [02/Sep/2015:01:52:17 -0700] "GET /dvwa/vulnerabilities/exec/ HTTP/1.1" 200 4477 "http://192.168.56.101/dvwa/security.php" "Mozilla/5.0 (X11; Linux x86_64; rv:38.0) Gecko/20100101 Firefox/38.0 Iceweasel/38.2.0"
192.168.56.102 - - [02/Sep/2015:01:52:17 -0700] "GET /dvwa/vulnerabilities/exec/ HTTP/1.1" 200 4477 "http://192.168.56.101/dvwa/security.php" "Mozilla/5.0 (X11; Linux x86_64; rv:38.0) Gecko/20100101 Firefox/38.0 Iceweasel/38.2.0"
192.168.56.102 - - [02/Sep/2015:01:52:29 -0700] "POST /dvwa/vulnerabilities/exec/ HTTP/1.1" 200 4508 "http://192.168.56.101/dvwa/vulnerabilities/exec/" "Mozilla/5.0 (X11; Linux x86_64; rv:38.0) Gecko/20100101 Firefox/38.0 Iceweasel/38.2.0"
192.168.56.102 - - [02/Sep/2015:01:53:02 -0700] "POST /dvwa/vulnerabilities/exec/ HTTP/1.1" 200 4943 "http://192.168.56.101/dvwa/vulnerabilities/exec/" "Mozilla/5.0 (X11; Linux x86_64; rv:38.0) Gecko/20100101 Firefox/38.0 Iceweasel/38.2.0"
192.168.56.102 - - [02/Sep/2015:01:53:30 -0700] "POST /dvwa/vulnerabilities/exec/ HTTP/1.1" 200 4943 "http://192.168.56.101/dvwa/vulnerabilities/exec/" "Mozilla/5.0 (X11; Linux x86_64; rv:38.0) Gecko/20100101 Firefox/38.0 Iceweasel/38.2.0"
192.168.56.102 - - [02/Sep/2015:01:54:30 -0700] "POST /dvwa/vulnerabilities/exec/ HTTP/1.1" 200 4508 "http://192.168.56.101/dvwa/vulnerabilities/exec/" "Mozilla/5.0 (X11; Linux x86_64; rv:38.0) Gecko/20100101 Firefox/38.0 Iceweasel/38.2.0"
192.168.56.102 - - [02/Sep/2015:01:55:44 -0700] "POST /dvwa/vulnerabilities/exec/ HTTP/1.1" 200 4508 "http://192.168.56.101/dvwa/vulnerabilities/exec/" "Mozilla/5.0 (X11; Linux x86_64; rv:38.0) Gecko/20100101 Firefox/38.0 Iceweasel/38.2.0"
192.168.56.102 - - [02/Sep/2015:01:56:30 -0700] "POST /dvwa/vulnerabilities/exec/ HTTP/1.1" 200 4943 "http://192.168.56.101/dvwa/vulnerabilities/exec/" "Mozilla/5.0 (X11; Linux x86_64; rv:38.0) Gecko/20100101 Firefox/38.0 Iceweasel/38.2.0"
192.168.56.102 - - [02/Sep/2015:01:57:30 -0700] "POST /dvwa/vulnerabilities/exec/ HTTP/1.1" 200 4515 "http://192.168.56.101/dvwa/vulnerabilities/exec/" "Mozilla/5.0 (X11; Linux x86_64; rv:38.0) Gecko/20100101 Firefox/38.0 Iceweasel/38.2.0"
192.168.56.102 - - [02/Sep/2015:01:58:13 -0700] "GET /dvwa/security.php HTTP/1.1" 200 4235 "http://192.168.56.101/dvwa/vulnerabilities/exec/" "Mozilla/5.0 (X11; Linux x86_64; rv:38.0) Gecko/20100101 Firefox/38.0 Iceweasel/38.2.0"
192.168.56.102 - - [02/Sep/2015:01:58:21 -0700] "GET /dvwa/vulnerabilities/exec/ HTTP/1.1" 200 4468 "http://192.168.56.101/dvwa/security.php" "Mozilla/5.0 (X11; Linux x86_64; rv:38.0) Gecko/20100101 Firefox/38.0 Iceweasel/38.2.0"
192.168.56.102 - - [02/Sep/2015:01:58:50 -0700] "POST /dvwa/vulnerabilities/exec/ HTTP/1.1" 200 8512 "http://192.168.56.101/dvwa/vulnerabilities/exec/" "Mozilla/5.0 (X11; Linux x86_64; rv:38.0) Gecko/20100101 Firefox/38.0 Iceweasel/38.2.0"
192.168.56.102 - - [02/Sep/2015:01:58:56 -0700] "GET /dvwa/security.php HTTP/1.1" 200 4235 "http://192.168.56.101/dvwa/vulnerabilities/exec/" "Mozilla/5.0 (X11; Linux x86_64; rv:38.0) Gecko/20100101 Firefox/38.0 Iceweasel/38.2.0"
192.168.56.102 - - [02/Sep/2015:01:58:57 -0700] "GET /dvwa/security.php HTTP/1.1" 200 4235 "http://192.168.56.101/dvwa/vulnerabilities/exec/" "Mozilla/5.0 (X11; Linux x86_64; rv:38.0) Gecko/20100101 Firefox/38.0 Iceweasel/38.2.0"
192.168.56.102 - - [02/Sep/2015:01:59:52 -0700] "POST /dvwa/vulnerabilities/exec/ HTTP/1.1" 200 4934 "http://192.168.56.101/dvwa/vulnerabilities/exec/" "Mozilla/5.0 (X11; Linux x86_64; rv:38.0) Gecko/20100101 Firefox/38.0 Iceweasel/38.2.0"
```

Local File Inclusion

```
192.168.56.102 - - [02/Sep/2015:01:43:29 -0700] "GET /dvwa/vulnerabilities/fi/. HTTP/1.1" 200 157 "-" "Mozilla/5.0 (compatible; MSIE 9.0; Windows NT 6.1; Win64; x64; Trident/5.0)"
192.168.56.102 - - [02/Sep/2015:01:43:29 -0700] "GET /dvwa/vulnerabilities/fi/ HTTP/1.1" 200 157 "-" "Mozilla/5.0 (compatible; MSIE 9.0; Windows NT 6.1; Win64; x64; Trident/5.0)"
192.168.56.102 - - [02/Sep/2015:01:43:29 -0700] "GET /dvwa/vulnerabilities/fi/.?page=include.php HTTP/1.1" 200 4223 "http://192.168.56.101/dvwa/index.php" "Mozilla/5.0 (compatible; MSIE 9.0; Windows NT 6.1; Win64; x64; Trident/5.0)"
192.168.56.102 - - [02/Sep/2015:01:43:30 -0700] "GET /dvwa/vulnerabilities/fi/ HTTP/1.1" 200 157 "http://192.168.56.101/dvwa/vulnerabilities/" "Mozilla/5.0 (compatible; MSIE 9.0; Windows NT 6.1; Win64; x64; Trident/5.0)"
192.168.56.102 - - [02/Sep/2015:02:30:17 -0700] "GET /dvwa/vulnerabilities/fi/?page=include.php HTTP/1.1" 200 4220 "http://192.168.56.101/dvwa/vulnerabilities/exec/" "Mozilla/5.0 (X11; Linux x86_64; rv:38.0) Gecko/20100101 Firefox/38.0 Iceweasel/38.2.0"
192.168.56.102 - - [02/Sep/2015:02:30:19 -0700] "GET /dvwa/vulnerabilities/fi/?page=include.php HTTP/1.1" 200 4220 "http://192.168.56.101/dvwa/vulnerabilities/exec/" "Mozilla/5.0 (X11; Linux x86_64; rv:38.0) Gecko/20100101 Firefox/38.0 Iceweasel/38.2.0"
192.168.56.102 - - [02/Sep/2015:02:31:16 -0700] "GET /dvwa/vulnerabilities/fi/?page=../../../../../../windows/system32/drivers/etc/hosts HTTP/1.1" 200 4397 "-" "Mozilla/5.0 (X11; Linux x86_64; rv:38.0) Gecko/20100101 Firefox/38.0 Iceweasel/38.2.0"
192.168.56.102 - - [02/Sep/2015:02:31:45 -0700] "GET /dvwa/vulnerabilities/exec/ HTTP/1.1" 200 4468 "http://192.168.56.101/dvwa/vulnerabilities/fi/?page=../../../../../../windows/system32/drivers/etc/hosts" "Mozilla/5.0 (X11; Linux x86_64; rv:38.0) Gecko/20100101 Firefox/38.0 Iceweasel/38.2.0"
192.168.56.102 - - [02/Sep/2015:02:33:23 -0700] "GET /dvwa/vulnerabilities/fi/?page=../../../../../../users/administrator/data.txt HTTP/1.1" 200 3641 "-" "Mozilla/5.0 (X11; Linux x86_64; rv:38.0) Gecko/20100101 Firefox/38.0 Iceweasel/38.2.0"
192.168.56.102 - - [02/Sep/2015:02:34:52 -0700] "GET /dvwa/vulnerabilities/fi/?page=../../../../../../xampp/phpmyadmin/config.inc HTTP/1.1" 200 4113 "-" "Mozilla/5.0 (X11; Linux x86_64; rv:38.0) Gecko/20100101 Firefox/38.0 Iceweasel/38.2.0"
192.168.56.102 - - [02/Sep/2015:02:35:36 -0700] "GET /dvwa/vulnerabilities/fi/?page=../../../../../../xampp/phpMyAdmin/config.inc HTTP/1.1" 200 4113 "-" "Mozilla/5.0 (X11; Linux x86_64; rv:38.0) Gecko/20100101 Firefox/38.0 Iceweasel/38.2.0"
192.168.56.102 - - [02/Sep/2015:02:35:49 -0700] "GET /dvwa/vulnerabilities/fi/?page=../../../../../../../xampp/phpMyAdmin/config.inc HTTP/1.1" 200 4125 "-" "Mozilla/5.0 (X11; Linux x86_64; rv:38.0) Gecko/20100101 Firefox/38.0 Iceweasel/38.2.0"
192.168.56.102 - - [02/Sep/2015:02:35:56 -0700] "GET /dvwa/setup.php HTTP/1.1" 200 3678 "http://192.168.56.101/dvwa/vulnerabilities/fi/?page=../../../../../../../xampp/phpMyAdmin/config.inc" "Mozilla/5.0 (X11; Linux x86_64; rv:38.0) Gecko/20100101 Firefox/38.0 Iceweasel/38.2.0"
192.168.56.102 - - [02/Sep/2015:02:36:00 -0700] "GET /dvwa/vulnerabilities/fi/?page=include.php HTTP/1.1" 200 4220 "http://192.168.56.101/dvwa/setup.php" "Mozilla/5.0 (X11; Linux x86_64; rv:38.0) Gecko/20100101 Firefox/38.0 Iceweasel/38.2.0"
192.168.56.102 - - [02/Sep/2015:02:36:21 -0700] "GET /dvwa/vulnerabilities/fi/?page=../../../../../../../xampp/phpMyAdmin/config.inc HTTP/1.1" 200 4125 "-" "Mozilla/5.0 (X11; Linux x86_64; rv:38.0) Gecko/20100101 Firefox/38.0 Iceweasel/38.2.0"
192.168.56.102 - - [02/Sep/2015:02:36:27 -0700] "GET /dvwa/vulnerabilities/fi/?page=../../../../../../../index HTTP/1.1" 200 4081 "-" "Mozilla/5.0 (X11; Linux x86_64; rv:38.0) Gecko/20100101 Firefox/38.0 Iceweasel/38.2.0"
192.168.56.102 - - [02/Sep/2015:02:36:39 -0700] "GET /dvwa/vulnerabilities/fi/?page=../../../../../../../users HTTP/1.1" 200 4052 "-" "Mozilla/5.0 (X11; Linux x86_64; rv:38.0) Gecko/20100101 Firefox/38.0 Iceweasel/38.2.0"
192.168.56.102 - - [02/Sep/2015:02:36:48 -0700] "GET /dvwa/vulnerabilities/fi/?page=../../../../../../../users/administrator/data.txt HTTP/1.1" 200 3641 "-" "Mozilla/5.0 (X11; Linux x86_64; rv:38.0) Gecko/20100101 Firefox/38.0 Iceweasel/38.2.0"
192.168.56.102 - - [02/Sep/2015:02:36:59 -0700] "GET /dvwa/vulnerabilities/fi/?page=../../../../../../../xampp/ HTTP/1.1" 200 4053 "-" "Mozilla/5.0 (X11; Linux x86_64; rv:38.0) Gecko/20100101 Firefox/38.0 Iceweasel/38.2.0"
192.168.56.102 - - [02/Sep/2015:02:37:18 -0700] "GET /dvwa/vulnerabilities/fi/?page=../../../../../../../xampp/readme_en HTTP/1.1" 200 4101 "-" "Mozilla/5.0 (X11; Linux x86_64; rv:38.0) Gecko/20100101 Firefox/38.0 Iceweasel/38.2.0"
192.168.56.102 - - [02/Sep/2015:02:37:21 -0700] "GET /dvwa/vulnerabilities/fi/?page=../../../../../../../xampp/readme_en.txt HTTP/1.1" 200 12218 "-" "Mozilla/5.0 (X11; Linux x86_64; rv:38.0) Gecko/20100101 Firefox/38.0 Iceweasel/38.2.0"
192.168.56.102 - - [02/Sep/2015:02:37:40 -0700] "GET /dvwa/vulnerabilities/fi/?page=../../../../../../../xampp/phpMyAdmin/config.inc.txt HTTP/1.1" 200 4133 "-" "Mozilla/5.0 (X11; Linux x86_64; rv:38.0) Gecko/20100101 Firefox/38.0 Iceweasel/38.2.0"
192.168.56.102 - - [02/Sep/2015:02:38:04 -0700] "GET /dvwa/vulnerabilities/fi/?page=../../../../../../../xampp/phpMyAdmin/ChangeLog HTTP/1.1" 200 21822 "-" "Mozilla/5.0 (X11; Linux x86_64; rv:38.0) Gecko/20100101 Firefox/38.0 Iceweasel/38.2.0"
192.168.56.102 - - [02/Sep/2015:02:38:28 -0700] "GET /dvwa/vulnerabilities/fi/?page=../../../../../../../xampp/phpMyAdmin/config.inc HTTP/1.1" 200 4125 "-" "Mozilla/5.0 (X11; Linux x86_64; rv:38.0) Gecko/20100101 Firefox/38.0 Iceweasel/38.2.0"
192.168.56.102 - - [02/Sep/2015:02:42:21 -0700] "GET /dvwa/vulnerabilities/fi/?page=../../../../../../../abc.txt HTTP/1.1" 200 4085 "-" "Mozilla/5.0 (X11; Linux x86_64; rv:38.0) Gecko/20100101 Firefox/38.0 Iceweasel/38.2.0"
192.168.56.102 - - [02/Sep/2015:23:38:58 -0700] "GET /dvwa/setup.php HTTP/1.1" 200 3678 "http://192.168.56.101/dvwa/vulnerabilities/fi/?page=../../../../../../../abc.txt" "Mozilla/5.0 (X11; Linux x86_64; rv:38.0) Gecko/20100101 Firefox/38.0 Iceweasel/38.2.0"
```

Cross-site Scripting

```
192.168.56.102 - - [02/Sep/2015:01:43:29 -0700] "GET /dvwa/vulnerabilities/xss_r/ HTTP/1.1" 200 4457 "-" "Mozilla/5.0 (compatible; MSIE 9.0; Windows NT 6.1; Win64; x64; Trident/5.0)"
192.168.56.102 - - [02/Sep/2015:01:43:29 -0700] "GET /dvwa/vulnerabilities/xss_r/. HTTP/1.1" 200 4457 "http://192.168.56.101/dvwa/index.php" "Mozilla/5.0 (compatible; MSIE 9.0; Windows NT 6.1; Win64; x64; T
192.168.56.102 - - [02/Sep/2015:01:43:29 -0700] "GET /dvwa/vulnerabilities/xss_s/ HTTP/1.1" 200 4991 "-" "Mozilla/5.0 (compatible; MSIE 9.0; Windows NT 6.1; Win64; x64; Trident/5.0)"
192.168.56.102 - - [02/Sep/2015:01:43:29 -0700] "GET /dvwa/vulnerabilities/xss_s/. HTTP/1.1" 200 4991 "http://192.168.56.101/dvwa/index.php" "Mozilla/5.0 (compatible; MSIE 9.0; Windows NT 6.1; Win64; x64; T
192.168.56.102 - - [02/Sep/2015:01:43:30 -0700] "GET /dvwa/vulnerabilities/xss_r/ HTTP/1.1" 200 4457 "http://192.168.56.101/dvwa/vulnerabilities/" "Mozilla/5.0 (compatible; MSIE 9.0; Windows NT 6.1; Win64; x
192.168.56.102 - - [02/Sep/2015:01:43:30 -0700] "GET /dvwa/vulnerabilities/xss_s/ HTTP/1.1" 200 4991 "http://192.168.56.101/dvwa/vulnerabilities/" "Mozilla/5.0 (compatible; MSIE 9.0; Windows NT 6.1; Win64; x
192.168.56.102 - - [02/Sep/2015:01:44:35 -0700] "GET /dvwa/vulnerabilities/xss_r/.?name=Peter%2bWinter HTTP/1.1" 200 4486 "http://192.168.56.101/dvwa/vulnerabilities/xss_r/." "Mozilla/5.0 (compatible; MSI
192.168.56.102 - - [02/Sep/2015:01:44:35 -0700] "POST /dvwa/vulnerabilities/xss_s/ HTTP/1.1" 200 5210 "http://192.168.56.101/dvwa/vulnerabilities/xss_s/" "Mozilla/5.0 (compatible; MSIE 9.0; Windows NT 6.1;
192.168.56.102 - - [02/Sep/2015:01:44:35 -0700] "POST /dvwa/vulnerabilities/xss_s/. HTTP/1.1" 200 5286 "http://192.168.56.101/dvwa/vulnerabilities/xss_s/." "Mozilla/5.0 (compatible; MSIE 9.0; Windows NT 6.1
192.168.56.102 - - [02/Sep/2015:01:44:35 -0700] "GET /dvwa/vulnerabilities/xss_r/.?name=Peter%2bWinter&name=Peter%2bWinter HTTP/1.1" 200 4492 "http://192.168.56.101/dvwa/vulnerabilities/xss_r/.?name
192.168.56.102 - - [02/Sep/2015:23:20:23 -0700] "GET /dvwa/vulnerabilities/xss_r/ HTTP/1.1" 200 4454 "http://192.168.56.101/dvwa/setup.php" "Mozilla/5.0 (X11; Linux x86_64; rv:38.0) Gecko/20100101 Firefox/38
192.168.56.102 - - [02/Sep/2015:23:20:58 -0700] "GET /dvwa/vulnerabilities/xss_r/?name=ali HTTP/1.1" 200 4474 "http://192.168.56.101/dvwa/vulnerabilities/xss_r/" "Mozilla/5.0 (X11; Linux x86_64; rv:38.0) Geck
192.168.56.102 - - [02/Sep/2015:23:21:04 -0700] "GET /dvwa/vulnerabilities/xss_r/ HTTP/1.1" 200 4454 "http://192.168.56.101/dvwa/vulnerabilities/xss_r/?name=ali" "Mozilla/5.0 (X11; Linux x86_64; rv:38.0) Geck
192.168.56.102 - - [02/Sep/2015:23:27:59 -0700] "GET /dvwa/vulnerabilities/xss_r/?name=Ali HTTP/1.1" 200 4474 "http://192.168.56.101/dvwa/vulnerabilities/xss_r/" "Mozilla/5.0 (X11; Linux x86_64; rv:38.0) Geck
192.168.56.102 - - [02/Sep/2015:23:29:00 -0700] "GET /dvwa/vulnerabilities/xss_r/?name=XSS HTTP/1.1" 200 4474 "http://192.168.56.101/dvwa/vulnerabilities/xss_r/?name=Ali" "Mozilla/5.0 (X11; Linux x86_64; r
```

Unrestricted file uploads

```
192.168.56.102 - - [03/Sep/2015:00:15:58 -0700] "GET /dvwa/hackable/uploads/phpshell.php HTTP/1.1" 200 277 "-" "Mozilla/5.0 (X11; Linux x86_64; rv:38.0) Gecko/20100101 Firefox/38.0 Iceweasel/38.2.0"
192.168.56.102 - - [03/Sep/2015:00:16:03 -0700] "GET /dvwa/hackable/uploads/phpshell.php?dir HTTP/1.1" 200 277 "-" "Mozilla/5.0 (X11; Linux x86_64; rv:38.0) Gecko/20100101 Firefox/38.0 Iceweasel/38.2.0"
192.168.56.102 - - [03/Sep/2015:00:16:13 -0700] "GET /dvwa/hackable/uploads/phpshell.php?cmd=dir HTTP/1.1" 200 419 "-" "Mozilla/5.0 (X11; Linux x86_64; rv:38.0) Gecko/20100101 Firefox/38.0 Iceweasel/38.2.0"
192.168.56.102 - - [03/Sep/2015:00:17:49 -0700] "GET /dvwa/hackable/uploads/phpshell.php?cmd=dir%20C:\\ HTTP/1.1" 200 1934 "-" "Mozilla/5.0 (X11; Linux x86_64; rv:38.0) Gecko/20100101 Firefox/38.0 Iceweasel/38.2.0"
192.168.56.102 - - [03/Sep/2015:00:17:58 -0700] "GET /dvwa/hackable/uploads/phpshell.php?cmd=mkdir%20abc HTTP/1.1" 200 - "-" "Mozilla/5.0 (X11; Linux x86_64; rv:38.0) Gecko/20100101 Firefox/38.0 Iceweasel/38.2.0"
192.168.56.102 - - [03/Sep/2015:00:18:02 -0700] "GET /dvwa/hackable/uploads/phpshell.php?cmd=dir HTTP/1.1" 200 463 "-" "Mozilla/5.0 (X11; Linux x86_64; rv:38.0) Gecko/20100101 Firefox/38.0 Iceweasel/38.2.0"
192.168.56.102 - - [03/Sep/2015:00:18:58 -0700] "GET /dvwa/hackable/uploads/phpshell.php HTTP/1.1" 200 277 "-" "Mozilla/5.0 (X11; Linux x86_64; rv:38.0) Gecko/20100101 Firefox/38.0 Iceweasel/38.2.0"
192.168.56.102 - - [03/Sep/2015:00:31:54 -0700] "GET /dvwa/hackable/uploads/phpshell2.php HTTP/1.1" 200 2 "-" "Mozilla/5.0 (X11; Linux x86_64; rv:38.0) Gecko/20100101 Firefox/38.0 Iceweasel/38.2.0"
```

Web Shells

```
192.168.56.102 - - [02/Sep/2015:04:25:52 -0700] "GET /xampp/htdocs/tmpukudk.php HTTP/1.1" 403 1206 "-" "sqlmap/1.0-dev-nongit-20150902 (http://sqlmap.org)"
192.168.56.102 - - [02/Sep/2015:04:25:53 -0700] "GET /htdocs/tmpukudk.php HTTP/1.1" 404 1059 "-" "sqlmap/1.0-dev-nongit-20150902 (http://sqlmap.org)"
192.168.56.102 - - [02/Sep/2015:04:25:53 -0700] "GET /tmpukudk.php HTTP/1.1" 200 315 "-" "sqlmap/1.0-dev-nongit-20150902 (http://sqlmap.org)"
192.168.56.102 - - [02/Sep/2015:04:25:53 -0700] "POST /tmpukudk.php HTTP/1.1" 200 25 "-" "Python-urllib/2.7"
192.168.56.102 - - [02/Sep/2015:04:25:53 -0700] "GET /tmpbiwuc.php?cmd=echo%20command%20execution%20test HTTP/1.1" 200 36 "-" "sqlmap/1.0-dev-nongit-20150902 (http://sqlmap.org)"
192.168.56.102 - - [02/Sep/2015:04:26:04 -0700] "GET /tmpbiwuc.php?cmd=dir HTTP/1.1" 200 853 "-" "sqlmap/1.0-dev-nongit-20150902 (http://sqlmap.org)"
192.168.56.102 - - [02/Sep/2015:04:26:23 -0700] "GET /tmpbiwuc.php?cmd=del%20%2FF%20%2FQ%20C%3A%5Cxampp%5Chtdocs%5Ctmpukudk.php HTTP/1.1" 200 11 "-" "sqlmap/1.0-dev-nongit-20150902 (http://sqlmap.org)"
192.168.56.102 - - [02/Sep/2015:04:26:23 -0700] "GET /tmpbiwuc.php?cmd=del%20%2FF%20%2FQ%20%5Cxampp%5Chtdocs%5Ctmpbiwuc.php HTTP/1.1" 200 11 "-" "sqlmap/1.0-dev-nongit-20150902 (http://sqlmap.org)"
192.168.56.102 - - [02/Sep/2015:23:52:24 -0700] "GET /xampp/htdocs/tmpudvfh.php HTTP/1.1" 403 1206 "-" "sqlmap/1.0-dev-nongit-20150902 (http://sqlmap.org)"
192.168.56.102 - - [02/Sep/2015:23:52:24 -0700] "GET /htdocs/tmpudvfh.php HTTP/1.1" 404 1059 "-" "sqlmap/1.0-dev-nongit-20150902 (http://sqlmap.org)"
192.168.56.102 - - [02/Sep/2015:23:52:24 -0700] "GET /tmpudvfh.php HTTP/1.1" 200 315 "-" "sqlmap/1.0-dev-nongit-20150902 (http://sqlmap.org)"
192.168.56.102 - - [02/Sep/2015:23:52:24 -0700] "POST /tmpudvfh.php HTTP/1.1" 200 25 "-" "Python-urllib/2.7"
192.168.56.102 - - [02/Sep/2015:23:52:24 -0700] "GET /tmpbrjvl.php?cmd=echo%20command%20execution%20test HTTP/1.1" 200 36 "-" "sqlmap/1.0-dev-nongit-20150902 (http://sqlmap.org)"
192.168.56.102 - - [02/Sep/2015:23:59:38 -0700] "GET /tmpbrjvl.php?cmd=del%20%2FF%20%2FQ%20C%3A%5Cxampp%5Chtdocs%5Ctmpudvfh.php HTTP/1.1" 200 11 "-" "sqlmap/1.0-dev-nongit-20150902 (http://sqlmap.org)"
192.168.56.102 - - [02/Sep/2015:23:59:38 -0700] "GET /tmpbrjvl.php?cmd=del%20%2FF%20%2FQ%20%5Cxampp%5Chtdocs%5Ctmpbrjvl.php HTTP/1.1" 200 11 "-" "sqlmap/1.0-dev-nongit-20150902 (http://sqlmap.org)"
```

2. How many users has the attacker added to the box, and how were they added?

500	0	23	2015-08-24 06:54:25	201...	2015-08-24 06:59:37	2...		Administrator			Administrators	Built-in account for administering the computer/domain
501	0	0	2015-08-24 06:54:25					Guest			Guests	Built-in account for guest access to the computer/domain
1005	0	0	2015-09-02 09:05:06		2015-09-02 09:05:06			user1			Users, Remote Desktop Users	
1006	0	0	2015-09-02 09:05:25		2015-09-02 09:05:25			hacker			Users, Remote Desktop Users	

The attacker added two unauthorized local user accounts: **user1** and **hacker**

user1 account was created manually through an interactive command prompt using the commands net user user1 <password> /add and later added to the "Remote Desktop Users" group with net localgroup.

Purpose: attacker created a remote-desktop capable backdoor.

2	CommandProcess: csrss.exe Pid: 524
3	CommandHistory: 0x5a24708 Application: cmd.exe Flags: Allocated, Reset
4	CommandCount: 17 LastAdded: 16 LastDisplayed: 16
5	FirstCommand: 0 CommandCountMax: 50
6	ProcessHandle: 0x2d8
7	Cmd #0 @ 0xe907c8: ipconfig
8	Cmd #1 @ 0xe91af8: cls
9	Cmd #2 @ 0xe91db0: ipconfig
10	Cmd #3 @ 0x5a34bd0: net user user1 user1 /add
11	Cmd #4 @ 0x5a34eb8: net user user1 root@psut /add
12	Cmd #5 @ 0x5a34c10: net user user1 Root@psut /add
13	Cmd #6 @ 0x5a24800: cls
14	Cmd #7 @ 0x5a34c58: net /?
15	Cmd #8 @ 0x5a34d88: net localgroup /?
16	Cmd #9 @ 0x5a34f48: net localgroup "Remote Desktop Users" user1 /add
17	Cmd #10 @ 0x5a34c70: net /?
18	Cmd #11 @ 0xe911b0: netsh /?
19	Cmd #12 @ 0xe907e8: netsh firewall /?
20	Cmd #13 @ 0xe91218: netsh firewall set service type = remotedesktop /?
21	Cmd #14 @ 0xe91288: netsh firewall set service type = remotedesktop enable
22	Cmd #15 @ 0xe91300: netsh firewall set service type=remotedesktop mode=enable
23	Cmd #16 @ 0xe91380: netsh firewall set service type=remotedesktop mode=enable scope=subnet

2. How many users has the attacker added to the box, and how were they added?

Process related to Apache server – 2796 & 2880 – httpd.exe

PID	PPID	ImageFileName	Offset(V	Threads	Handles	Session	Wow64	CreateTime	ExitTime	Audit	Cmd	Path
** 2796	2768	httpd.exe	0x83e4d7c	1	92	1	FALSE	2015-08-23 10:32:21.000000	N/A	\Device\Hi	c:\xampp\	c:\xampp\apache\bin\httpd.exe
*** 2880	2796	httpd.exe	0x83fd77a	155	483	1	FALSE	2015-08-23 10:32:26.000000	N/A	\Device\Hi	C:\xampp	C:\xampp\apache\bin\httpd.exe

dump their memory space to run string searches – finding 'hacker' account creation

```
PS D:\DFIR\Vol2\volatility_2.6_win64_standalone\volatility_2.6_win64_standalone> .\volatility -f "D:\DFIR\DFIR_Web Serve
r Case\memdump\memdump.mem" --profile=VistaSP1x86 memdump -p 2796 --dump-dir "D:\DFIR\DFIR_Web Server Case\analysis"
Volatility Foundation Volatility Framework 2.6
************************************************************************
Writing httpd.exe [  2796] to 2796.dmp
PS D:\DFIR\Vol2\volatility_2.6_win64_standalone\volatility_2.6_win64_standalone> .\volatility -f "D:\DFIR\DFIR_Web Serve
r Case\memdump\memdump.mem" --profile=VistaSP1x86 memdump -p 2880 --dump-dir "D:\DFIR\DFIR_Web Server Case\analysis"
Volatility Foundation Volatility Framework 2.6
************************************************************************
Writing httpd.exe [  2880] to 2880.dmp
```

```
PS D:\DFIR\Vol2\volatility_2.6_win64_standalone\volatility_2.6_win64_standalone\Strings> .\strings.exe "D:\DFIR\DFIR_Web
 Server Case\analysis\2796.dmp" > "D:\DFIR\DFIR_Web Server Case\analysis\2796_strings.txt"
PS D:\DFIR\Vol2\volatility_2.6_win64_standalone\volatility_2.6_win64_standalone\Strings> .\strings.exe "D:\DFIR\DFIR_Web
 Server Case\analysis\2880.dmp" > "D:\DFIR\DFIR_Web Server Case\analysis\2880_strings.txt"
PS D:\DFIR\Vol2\volatility_2.6_win64_standalone\volatility_2.6_win64_standalone\Strings>
```

Output from first dump – we see how 'hacker' account was created

```
PS D:\DFIR\Vol2\volatility_2.6_win64_standalone\volatility_2.6_win64_standalone\strings> Select-String -Pattern "hacker"
 -Path "D:\DFIR\DFIR_Web Server Case\analysis\2796_strings.txt"

D:\DFIR\DFIR_Web Server Case\analysis\2796_strings.txt:55774:4391552:~^webwhacker.*$~
D:\DFIR\DFIR_Web Server Case\analysis\2796_strings.txt:56313:4422396:WebWhacker*
D:\DFIR\DFIR_Web Server Case\analysis\2796_strings.txt:56848:4454848:WebWhacker*
D:\DFIR\DFIR_Web Server Case\analysis\2796_strings.txt:56849:4454920:WebWhacker
D:\DFIR\DFIR_Web Server
Case\analysis\2796_strings.txt:512454:44835418:Zp6.102+%26%26+net+user+hacker+hacker+/add&submit=submit
D:\DFIR\DFIR_Web Server Case\analysis\2796_strings.txt:517048:45830736:ip=192.168.56.102+%26%26+net+localgroup+%22Remot
e+Desktop+Users%22+hacker+%2Fadd&submit=submit$
D:\DFIR\DFIR_Web Server Case\analysis\2796_strings.txt:1588002:123490168:hackerLo
D:\DFIR\DFIR_Web Server Case\analysis\2796_strings.txt:1588070:123496436:hacker
```

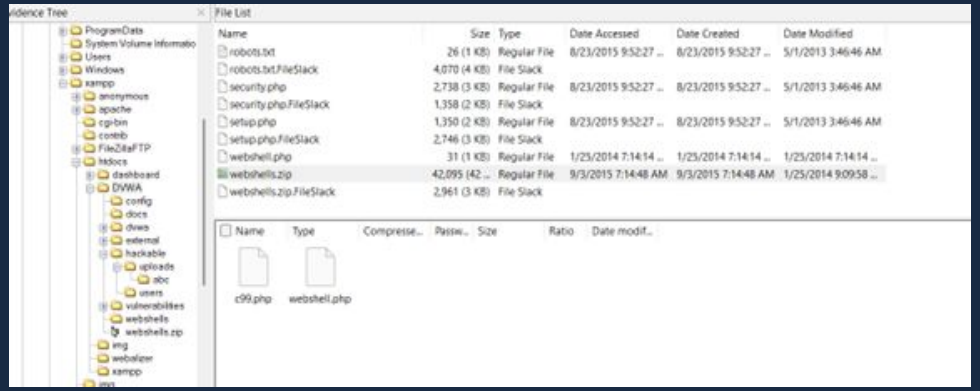
Output from second dump

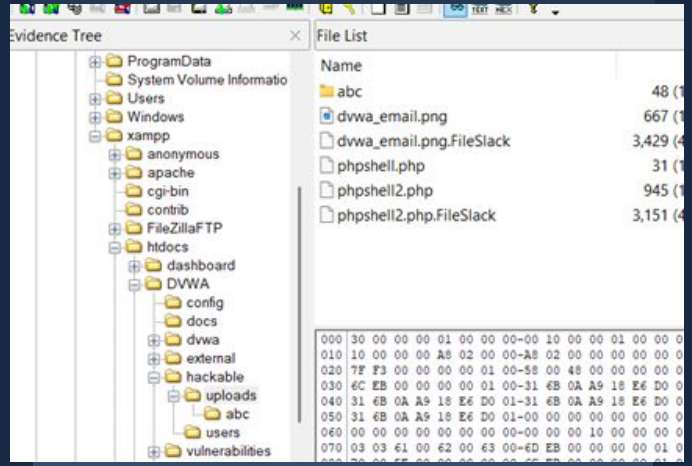
```
PS D:\DFIR\Vol2\volatility_2.6_win64_standalone\volatility_2.6_win64_standalone\strings> Select-String -Pattern "hacker"
 -Path "D:\DFIR\DFIR_Web Server Case\analysis\2880_strings.txt"

D:\DFIR\DFIR_Web Server Case\analysis\2880_strings.txt:53643:4144432:~^webwhacker.*$~
D:\DFIR\DFIR_Web Server Case\analysis\2880_strings.txt:53916:4154876:WebWhacker*
D:\DFIR\DFIR_Web Server Case\analysis\2880_strings.txt:54450:4187328:WebWhacker*
D:\DFIR\DFIR_Web Server Case\analysis\2880_strings.txt:54451:4187400:WebWhacker
D:\DFIR\DFIR_Web Server Case\analysis\2880_strings.txt:306875:18743560:<center><b>Owned by hacker</b></center>
D:\DFIR\DFIR_Web Server Case\analysis\2880_strings.txt:310475:18919688:<center><b>Owned by hacker</b></center>
D:\DFIR\DFIR_Web Server Case\analysis\2880_strings.txt:342227:21119256:<center><b>Owned by hacker</b></center>
D:\DFIR\DFIR_Web Server Case\analysis\2880_strings.txt:346442:21389576:<center><b>Owned by hacker</b></center>
D:\DFIR\DFIR_Web Server Case\analysis\2880_strings.txt:350543:21577688:<center><b>Owned by hacker</b></center>
D:\DFIR\DFIR_Web Server
Case\analysis\2880_strings.txt:794909:61211226:Zp6.102+%26%26+net+user+hacker+hacker+/add&submit=submit
D:\DFIR\DFIR_Web Server Case\analysis\2880_strings.txt:799503:62206544:ip=192.168.56.102+%26%26+net+localgroup+%22Remot
e+Desktop+Users%22+hacker+%2Fadd&submit=submit$
D:\DFIR\DFIR_Web Server Case\analysis\2880_strings.txt:1870458:139865976:hackerLo
D:\DFIR\DFIR_Web Server Case\analysis\2880_strings.txt:1870526:139872244:hacker
```

hacker account was created through a web-based PHP shell, proven by URL-encoded command strings (net+user+hacker+hacker+/add) found in the memory space of Apache worker processes (PIDs 2796 and 2880).

3.What leftovers did the attacker leave behind?





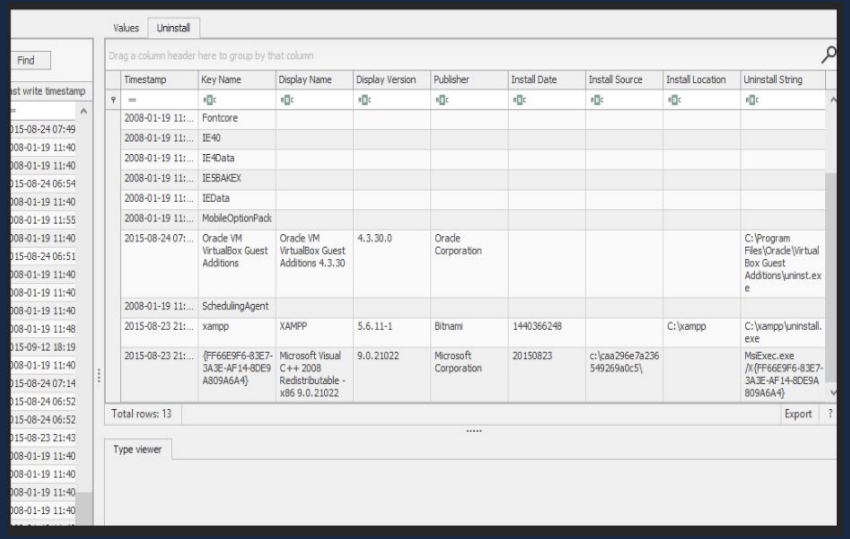

```
192.168.56.102 - - [02/Sep/2015:01:43:29 -0700] "GET /dvwa/vulnerabilities/upload/. HTTP/1.1" 200 4656 "http://192.168.56.101/dvwa/index.php" "Mozilla/5.0 (compatible; MSIE 9.0; Windows NT 6.1; Win64; x64; Trident/5.0)"
192.168.56.102 - - [02/Sep/2015:01:43:29 -0700] "GET /dvwa/vulnerabilities/upload/ HTTP/1.1" 200 4656 "-" "Mozilla/5.0 (compatible; MSIE 9.0; Windows NT 6.1; Win64; x64; Trident/5.0)"
192.168.56.102 - - [02/Sep/2015:01:43:30 -0700] "GET /dvwa/vulnerabilities/upload/ HTTP/1.1" 200 4656 "http://192.168.56.101/dvwa/vulnerabilities/" "Mozilla/5.0 (compatible; MSIE 9.0; Windows NT 6.1; Win64; x64; Trident/5.0)"
192.168.56.102 - - [03/Sep/2015:00:08:35 -0700] "GET /dvwa/vulnerabilities/upload/ HTTP/1.1" 200 4653 "http://192.168.56.101/dvwa/setup.php" "Mozilla/5.0 (X11; Linux x86_64; rv:38.0) Gecko/20100101 Firefox/38.0 Iceweasel/38.2.0"
192.168.56.102 - - [03/Sep/2015:00:10:15 -0700] "POST /dvwa/vulnerabilities/upload/ HTTP/1.1" 200 4721 "http://192.168.56.101/dvwa/vulnerabilities/upload/" "Mozilla/5.0 (X11; Linux x86_64; rv:38.0) Gecko/20100101 Firefox/38.0 Iceweasel/38.2.0"
192.168.56.102 - - [03/Sep/2015:00:10:56 -0700] "GET /dvwa/vulnerabilities/upload/ HTTP/1.1" 200 4653 "http://192.168.56.101/dvwa/" "Mozilla/5.0 (X11; Linux x86_64; rv:38.0) Gecko/20100101 Firefox/38.0 Iceweasel/38.2.0"
192.168.56.102 - - [03/Sep/2015:00:15:58 -0700] "GET /dvwa/hackable/uploads/phpshell.php HTTP/1.1" 200 277 "-" "Mozilla/5.0 (X11; Linux x86_64; rv:38.0) Gecko/20100101 Firefox/38.0 Iceweasel/38.2.0"
192.168.56.102 - - [03/Sep/2015:00:16:03 -0700] "GET /dvwa/hackable/uploads/phpshell.php?dir HTTP/1.1" 200 277 "-" "Mozilla/5.0 (X11; Linux x86_64; rv:38.0) Gecko/20100101 Firefox/38.0 Iceweasel/38.2.0"
192.168.56.102 - - [03/Sep/2015:00:16:13 -0700] "GET /dvwa/hackable/uploads/phpshell.php?cmd=dir HTTP/1.1" 200 419 "-" "Mozilla/5.0 (X11; Linux x86_64; rv:38.0) Gecko/20100101 Firefox/38.0 Iceweasel/38.2.0"
192.168.56.102 - - [03/Sep/2015:00:17:49 -0700] "GET /dvwa/hackable/uploads/phpshell.php?cmd=dir%20C:\\ HTTP/1.1" 200 1934 "-" "Mozilla/5.0 (X11; Linux x86_64; rv:38.0) Gecko/20100101 Firefox/38.0 Iceweasel/38.2.0"
192.168.56.102 - - [03/Sep/2015:00:17:58 -0700] "GET /dvwa/hackable/uploads/phpshell.php?cmd=mkdir%20abc HTTP/1.1" 200 - "-" "Mozilla/5.0 (X11; Linux x86_64; rv:38.0) Gecko/20100101 Firefox/38.0 Iceweasel/38.2.0"
192.168.56.102 - - [03/Sep/2015:00:18:02 -0700] "GET /dvwa/hackable/uploads/phpshell.php?cmd=dir HTTP/1.1" 200 463 "-" "Mozilla/5.0 (X11; Linux x86_64; rv:38.0) Gecko/20100101 Firefox/38.0 Iceweasel/38.2.0"
192.168.56.102 - - [03/Sep/2015:00:18:58 -0700] "GET /dvwa/hackable/uploads/phpshell.php HTTP/1.1" 200 277 "-" "Mozilla/5.0 (X11; Linux x86_64; rv:38.0) Gecko/20100101 Firefox/38.0 Iceweasel/38.2.0"
192.168.56.102 - - [03/Sep/2015:00:31:18 -0700] "GET /dvwa/vulnerabilities/upload/ HTTP/1.1" 200 4653 "http://192.168.56.101/dvwa/" "Mozilla/5.0 (X11; Linux x86_64; rv:38.0) Gecko/20100101 Firefox/38.0 Iceweasel/38.2.0"
192.168.56.102 - - [03/Sep/2015:00:31:30 -0700] "POST /dvwa/vulnerabilities/upload/ HTTP/1.1" 200 4722 "http://192.168.56.101/dvwa/vulnerabilities/upload/" "Mozilla/5.0 (X11; Linux x86_64; rv:38.0) Gecko/20100101 Firefox/38.0 Iceweasel/38.2.0"
192.168.56.102 - - [03/Sep/2015:00:31:54 -0700] "GET /dvwa/hackable/uploads/phpshell2.php HTTP/1.1" 200 2 "-" "Mozilla/5.0 (X11; Linux x86_64; rv:38.0) Gecko/20100101 Firefox/38.0 Iceweasel/38.2.0"
```

3.What leftovers did the attacker leave behind?

The attacker left behind multiple PHP webshells, a malicious upload directory, suspicious PNG files with hidden slack-space data, defacement HTML, webshell command execution logs, memory-resident traces of account creation commands, and two unauthorized Windows accounts used for persistence.

1. **c99.php** – malicious C99 webshell (found in /uploads/abc/).
2. **phpshell.php** – primary PHP command webshell (in /uploads/).
3. **phpshell2.php** – secondary PHP webshell (in /uploads/).
4. **abc/** – attacker-created directory.
5. **dvwa_email.png.FileSlack / dvwa_email2.png.FileSlack** – images with hidden slack-space data.
6. **"Owned by hacker"** HTML – defacement content found in memory.
7. Malicious command strings – encoded **net user** & **net localgroup** commands in Apache process memory.
8. Unauthorized accounts – **user1** (RDP-enabled) and **hacker** (webshell-created).

4.What software has been installed on the box and were they installed by the attacker?



Values | Uninstall

Find

Drag a column header here to group by that column

Timestamp	Key Name	Display Name	Display Version	Publisher	Install Date	Install Source	Install Location	Uninstall String
2008-01-19 11:...	Fontcore							
2008-01-19 11:...	IE40							
2008-01-19 11:...	IE4Data							
2008-01-19 11:...	IESBAKEX							
2008-01-19 11:...	IEData							
2008-01-19 11:...	MobileOptionPack							
2015-08-24 07:...	Oracle VM VirtualBox Guest Additions	Oracle VM VirtualBox Guest Additions 4.3.30	4.3.30.0	Oracle Corporation				C:\Program Files\Oracle\Virtual Box Guest Additions\uninst.exe
2008-01-19 11:...	SchedulingAgent							
2015-08-23 21:...	xampp	XAMPP	5.6.11-1	Bitnami	1440366248		C:\xampp	C:\xampp\uninstall.exe
2015-08-23 21:...	{FF66E9F6-83E7-3A3E-AF14-8DE9A809A6A4}	Microsoft Visual C++ 2008 Redistributable - x86 9.0.21022	9.0.21022	Microsoft Corporation	20150823	c:\caa296e7a236549269a0c5\		MsiExec.exe /X{FF66E9F6-83E7-3A3E-AF14-8DE9A809A6A4}

Total rows: 13 | Export | ?

Type viewer

None of the installed programs found in ‘HKEY_LOCAL_MACHINE\Software\Microsoft\Windows\CurrentVersion\Uninstall’ were added by the attacker. Instead, the attacker relied on uploading PHP webshells into the existing XAMPP/DVWA environment rather than installing new software, meaning no registry-visible installations were performed by the attacker.

5.Using memory forensics can you identify the type of shell code used?

```
192.168.56.102 - - [02/Sep/2015:04:25:52 -0700] "GET /xampp/htdocs/tmpukudk.php HTTP/1.1" 403 1206 "-" "sqlmap/1.0-dev-nongit-20150902 (http://sqlmap.org)"
192.168.56.102 - - [02/Sep/2015:04:25:53 -0700] "GET /htdocs/tmpukudk.php HTTP/1.1" 404 1059 "-" "sqlmap/1.0-dev-nongit-20150902 (http://sqlmap.org)"
192.168.56.102 - - [02/Sep/2015:04:25:53 -0700] "GET /tmpukudk.php HTTP/1.1" 200 315 "-" "sqlmap/1.0-dev-nongit-20150902 (http://sqlmap.org)"
192.168.56.102 - - [02/Sep/2015:04:25:53 -0700] "POST /tmpukudk.php HTTP/1.1" 200 25 "-" "Python-urllib/2.7"
192.168.56.102 - - [02/Sep/2015:04:25:53 -0700] "GET /tmpbiwuc.php?cmd=echo%20command%20execution%20test HTTP/1.1" 200 36 "-" "sqlmap/1.0-dev-nongit-20150902 (http://sqlmap.org)"
192.168.56.102 - - [02/Sep/2015:04:26:04 -0700] "GET /tmpbiwuc.php?cmd=dir HTTP/1.1" 200 853 "-" "sqlmap/1.0-dev-nongit-20150902 (http://sqlmap.org)"
192.168.56.102 - - [02/Sep/2015:04:26:23 -0700] "GET /tmpbiwuc.php?cmd=del%20%2FF%20%2FQ%20C%3A%5Cxampp%5Chtdocs%5Ctmpukudk.php HTTP/1.1" 200 11 "-" "sqlmap/1.0-dev-nongit-20150902 (http://sqlmap.org)"
192.168.56.102 - - [02/Sep/2015:04:26:23 -0700] "GET /tmpbiwuc.php?cmd=del%20%2FF%20%2FQ%20%5Cxampp%5Chtdocs%5Ctmpbiwuc.php HTTP/1.1" 200 11 "-" "sqlmap/1.0-dev-nongit-20150902 (http://sqlmap.org)"
192.168.56.102 - - [02/Sep/2015:23:52:24 -0700] "GET /xampp/htdocs/tmpudvfh.php HTTP/1.1" 403 1206 "-" "sqlmap/1.0-dev-nongit-20150902 (http://sqlmap.org)"
192.168.56.102 - - [02/Sep/2015:23:52:24 -0700] "GET /htdocs/tmpudvfh.php HTTP/1.1" 404 1059 "-" "sqlmap/1.0-dev-nongit-20150902 (http://sqlmap.org)"
192.168.56.102 - - [02/Sep/2015:23:52:24 -0700] "GET /tmpudvfh.php HTTP/1.1" 200 315 "-" "sqlmap/1.0-dev-nongit-20150902 (http://sqlmap.org)"
192.168.56.102 - - [02/Sep/2015:23:52:24 -0700] "POST /tmpudvfh.php HTTP/1.1" 200 25 "-" "Python-urllib/2.7"
192.168.56.102 - - [02/Sep/2015:23:52:24 -0700] "GET /tmpbrjvl.php?cmd=echo%20command%20execution%20test HTTP/1.1" 200 36 "-" "sqlmap/1.0-dev-nongit-20150902 (http://sqlmap.org)"
192.168.56.102 - - [02/Sep/2015:23:59:38 -0700] "GET /tmpbrjvl.php?cmd=del%20%2FF%20%2FQ%20C%3A%5Cxampp%5Chtdocs%5Ctmpudvfh.php HTTP/1.1" 200 11 "-" "sqlmap/1.0-dev-nongit-20150902 (http://sqlmap.org)"
192.168.56.102 - - [02/Sep/2015:23:59:38 -0700] "GET /tmpbrjvl.php?cmd=del%20%2FF%20%2FQ%20%5Cxampp%5Chtdocs%5Ctmpbrjvl.php HTTP/1.1" 200 11 "-" "sqlmap/1.0-dev-nongit-20150902 (http://sqlmap.org)"
```

```
192.168.56.102 - - [02/Sep/2015:04:20:21 -0700] "GET /dvwa/vulnerabilities/sqli/?id=2%27%3BSELECT%20BENCHMARK%285000000%2CMD5%280x76446447%29%29%23&Submit=Submit HTTP/1.1" 200 201 "-" "sqlmap/1.0-dev-nongit-20150902 (http://sqlmap.org)"
192.168.56.102 - - [02/Sep/2015:04:20:21 -0700] "GET /dvwa/vulnerabilities/sqli/?id=2%27%3BSELECT%20BENCHMARK%285000000%2CMD5%280x6a755976%29%29%20AND%20%27GgSr%27%3D%27GgSr&Submit=Submit HTTP/1.1" 200 217 "-" "sqlmap/1.0-dev-nongit-20150902 (http://sqlmap.org)"
192.168.56.102 - - [02/Sep/2015:04:22:13 -0700] "GET /dvwa/vulnerabilities/sqli/?id=2%27%3BSELECT%20BENCHMARK%285000000%2CMD5%280x627a6b6d%29%29%23&Submit=Submit HTTP/1.1" 200 201 "-" "sqlmap/1.0-dev-nongit-20150902 (http://sqlmap.org)"
192.168.56.102 - - [02/Sep/2015:04:22:13 -0700] "GET /dvwa/vulnerabilities/sqli/?id=2%27%3BSELECT%20BENCHMARK%285000000%2CMD5%280x54425171%29%29%20AND%20%27DthE%27%3D%27DthE&Submit=Submit HTTP/1.1" 200 217 "-" "sqlmap/1.0-dev-nongit-20150902 (http://sqlmap.org)"
192.168.56.102 - - [02/Sep/2015:04:25:53 -0700] "GET /tmpbiwuc.php?cmd=echo%20command%20execution%20test HTTP/1.1" 200 36 "-" "sqlmap/1.0-dev-nongit-20150902 (http://sqlmap.org)"
192.168.56.102 - - [02/Sep/2015:04:26:04 -0700] "GET /tmpbiwuc.php?cmd=dir HTTP/1.1" 200 853 "-" "sqlmap/1.0-dev-nongit-20150902 (http://sqlmap.org)"
192.168.56.102 - - [02/Sep/2015:04:26:23 -0700] "GET /tmpbiwuc.php?cmd=del%20%2FF%20%2FQ%20C%3A%5Cxampp%5Chtdocs%5Ctmpukudk.php HTTP/1.1" 200 11 "-" "sqlmap/1.0-dev-nongit-20150902 (http://sqlmap.org)"
192.168.56.102 - - [02/Sep/2015:04:26:23 -0700] "GET /tmpbiwuc.php?cmd=del%20%2FF%20%2FQ%20%5Cxampp%5Chtdocs%5Ctmpbiwuc.php HTTP/1.1" 200 11 "-" "sqlmap/1.0-dev-nongit-20150902 (http://sqlmap.org)"
192.168.56.102 - - [02/Sep/2015:23:52:24 -0700] "GET /tmpbrjvl.php?cmd=echo%20command%20execution%20test HTTP/1.1" 200 36 "-" "sqlmap/1.0-dev-nongit-20150902 (http://sqlmap.org)"
192.168.56.102 - - [02/Sep/2015:23:59:38 -0700] "GET /tmpbrjvl.php?cmd=del%20%2FF%20%2FQ%20C%3A%5Cxampp%5Chtdocs%5Ctmpudvfh.php HTTP/1.1" 200 11 "-" "sqlmap/1.0-dev-nongit-20150902 (http://sqlmap.org)"
192.168.56.102 - - [02/Sep/2015:23:59:38 -0700] "GET /tmpbrjvl.php?cmd=del%20%2FF%20%2FQ%20%5Cxampp%5Chtdocs%5Ctmpbrjvl.php HTTP/1.1" 200 11 "-" "sqlmap/1.0-dev-nongit-20150902 (http://sqlmap.org)"
192.168.56.102 - - [03/Sep/2015:00:16:13 -0700] "GET /dvwa/hackable/uploads/phpshell.php?cmd=dir HTTP/1.1" 200 419 "-" "Mozilla/5.0 (X11; Linux x86_64; rv:38.0) Gecko/20100101 Firefox/38.0 Iceweasel/38.2.0"
192.168.56.102 - - [03/Sep/2015:00:17:49 -0700] "GET /dvwa/hackable/uploads/phpshell.php?cmd=dir%20C:\\ HTTP/1.1" 200 1934 "-" "Mozilla/5.0 (X11; Linux x86_64; rv:38.0) Gecko/20100101 Firefox/38.0 Iceweasel/38.2.0"
192.168.56.102 - - [03/Sep/2015:00:17:58 -0700] "GET /dvwa/hackable/uploads/phpshell.php?cmd=mkdir%20abc HTTP/1.1" 200 - "-" "Mozilla/5.0 (X11; Linux x86_64; rv:38.0) Gecko/20100101 Firefox/38.0 Iceweasel/38.2.0"
192.168.56.102 - - [03/Sep/2015:00:18:02 -0700] "GET /dvwa/hackable/uploads/phpshell.php?cmd=dir HTTP/1.1" 200 463 "-" "Mozilla/5.0 (X11; Linux x86_64; rv:38.0) Gecko/20100101 Firefox/38.0 Iceweasel/38.2.0"
192.168.56.102 - - [03/Sep/2015:00:21:28 -0700] "POST /dvwa/c99.php?act=cmd HTTP/1.1" 200 13100 "http://192.168.56.101/dvwa/c99.php" "Mozilla/5.0 (X11; Linux x86_64; rv:38.0) Gecko/20100101 Firefox/38.0 Iceweasel/38.2.0"
192.168.56.102 - - [03/Sep/2015:00:21:37 -0700] "POST /dvwa/c99.php?act=cmd HTTP/1.1" 200 14176 "http://192.168.56.101/dvwa/c99.php?act=cmd" "Mozilla/5.0 (X11; Linux x86_64; rv:38.0) Gecko/20100101 Firefox/38.0 Iceweasel/38.2.0"
```

All evidence from the logs and memory strings indicates that the attacker relied on PHP-based webshell payloads uploaded through SQLMap and custom PHP shells (including C99 and phpshell.php). These PHP webshells were used to execute system commands through Apache instead of injecting traditional shellcode into memory.

6.What is the timeline analysis for all events that happened on the box?

02/09/2015 00:05:06 (SAM hive) — System timestamp logs the creation of user1.

02/09/2015 00:05:25 (SAM hive) — System timestamp logs the creation of hacker.

02/09/2015 00:10:41 — Requests from the IP 192.168.56.102 start coming in from IceWeasel (Kali Linux) to the XAMPP dashboard on 192.168.56.101.

02/09/2015 01:43:29 — Attacker first browses multiple DVWA vulnerabilities (/vulnerabilities/sqli/, /exec/, /brute/, /xss_r/, /fi/) to map attack surface.

02/09/2015 01:43:29 — LFI endpoint /dvwa/vulnerabilities/fi/ is accessed with page= parameters, starting local file inclusion attempts.

02/09/2015 01:43:29 — SQLi endpoint /dvwa/vulnerabilities/sqli/ is accessed, beginning SQL injection testing.

02/09/2015 01:43:29 — Brute-force and XSS modules (/vulnerabilities/brute/ and /vulnerabilities/xss_r/) are reached and tested from the same attacking IP.

02/09/2015 01:50:33 — exec endpoint /dvwa/vulnerabilities/exec/ is hit via POST, indicating active command injection (OS commands being submitted through the form).

02/09/2015 04:15:40 — SQLMap starts automated SQL injection against DVWA; user-agent sqlmap/1.0-dev-nongit-20150902 appears in the logs targeting /dvwa/vulnerabilities/sqli/.

02/09/2015 04:25:52 — SQLMap drops and uses temporary PHP stager files (tmpukudk.php, tmpbiwuc.php, etc.) under the web root to execute remote commands via cmd= parameters.

03/09/2015 00:15:58 — Manually uploaded webshell phpshell.php in /dvwa/hackable/uploads/ is first accessed and used (including requests like phpshell.php?cmd=dir).

03/09/2015 00:19:32 — C99 PHP webshell (/dvwa/c99.php) is first loaded in the browser, giving the attacker a full-featured file manager and command interface.

03/09/2015 00:21:28 — Commands are executed through the C99 webshell (/dvwa/c99.php?act=cmd via POST), confirming interactive remote command execution via the backdoor.

03/09/2015 00:31:54 — Secondary uploaded PHP webshell phpshell2.php in /dvwa/hackable/uploads/ is accessed, providing an additional command-execution foothold.

7.What is your hypothesis for the case and what is your approach in solving it?

The attacker exploited multiple known vulnerabilities in the intentionally insecure DVWA web application running on an XAMPP server. They performed reconnaissance through SQLi, XSS, LFI, and brute-force attacks, then escalated to command injection. Using SQLMap automation and DVWA's vulnerable file upload functionality, they uploaded multiple PHP webshells, including C99, gaining full remote command execution. With this access, the attacker created persistent Windows user accounts (user1 and hacker) to maintain long-term system access. The motive appears to be full system compromise, persistence, and control, rather than data exfiltration.

The attacker compromised the DVWA/XAMPP environment using multiple vulnerabilities and escalated to system-level access by deploying PHP webshells and creating new Windows user accounts. The investigation approach combined log, file-system, memory, and registry forensics to reconstruct the attack path, confirm persistence mechanisms, and validate the hypothesis of a full-system compromise.

8.Is there anything else you would like to add ?

In conclusion, the attacker successfully exploited multiple DVWA vulnerabilities to gain system-level access, deploy PHP webshells, and create persistent user accounts. The evidence clearly shows a full compromise of the XAMPP server. This investigation demonstrates the importance of securing web applications, monitoring logs, and restricting access to vulnerable environments.